Risk Assessment Report

Implementation of the Information Security Management System

(ISO/IEC 27001:2022)

Document Classification	Internal
Version	1.0
Dated	04/02/27
Document Owner	NX Technologies

Note: NX Technologies is a fictional company. This document is a sample created for learning and portfolio purposes only.

Document Governance & Control

Revision History

VERSION	DATE	AUTHOR	DESCRIPTION
1.0	04/02/27	Aarti Narwade	Initial draft for Risk Assessment Report

Distribution

NAME	TITLE
Aakash	CEO
Suvarna	CISO
Rahul	CTO

Approval and Sign-Off

NAME	POSITION	SIGNATURE	DATE
Aakash	CEO	Pending	-
Suvarna	CISO	Pending	-
Rahul	CTO	Pending	-

Contents

1. Introduction.....3
2. Risk Assessment Context.....3
2.1 Internal and External Context.....3
2.2 Scope.....3
2.3 Criteria for Performing Information Security Risk Assessment.....3
2.3.1 Asset Valuation Criteria.....3
2.3.2 Risk Likelihood and Impact Criteria.....3
2.3.3 Risk Scoring.....3
3. Risk Assessment Results Summary.....4
3.1 Asset-Based Risk Assessment.....4
4. Appendix A: Detailed Risk Assessment.....5
Asset-Based Risk Assessment (Detailed).....5

1. Introduction

This report outlines the risk assessment conducted for NX Technologies as part of its ISO/IEC 27001:2022 compliance efforts. The purpose is to identify, analyze, and prioritize information security risks that could impact the organization's assets, data, and operations. This report will serve as a foundation for developing risk treatment plans.

2. Risk Assessment Context

2.1 Internal and External Context

- **Internal Context:** NX Technologies operates as a technology services firm specializing in information security training, GRC, and advisory services. The company's key assets include IT infrastructure (web servers, CRM systems, workstations, and cloud services), employee laptops, and third-party services for lab practices.
- **External Context:** The company faces an evolving threat landscape, with cybersecurity threats from unauthorized access, data breaches, malware, and phishing attacks. These threats are heightened by reliance on cloud-based infrastructure and external service providers.

2.2 Scope

The scope of this risk assessment includes:

- Web servers hosted externally.
- Cloud-based CRM system.
- Employee laptops.
- Google Workspace.
- Third-party applications.
- Cloud Infrastructure and Storage

2.3 Criteria for Performing Information Security Risk Assessment

2.3.1 Asset Valuation Criteria

Assets are evaluated based on confidentiality, integrity, and availability.

2.3.2 Risk Likelihood and Impact Criteria

- **Likelihood:** Measures the probability of the risk occurring.
- **Impact:** Measures the consequences if the risk occurs.

Both likelihood and impact are scored on a 5-point scale (1 being low, 5 being high). The scale labels and risk levels are defined in the Risk Assessment and Risk Treatment Process document.

2.3.3 Risk Scoring

The Risk Score is calculated by multiplying the likelihood and impact, resulting in a score from 1 to 25, which determines the risk level (Low 1-6, Medium 7-14, High 15-25).

3. Risk Assessment Results Summary

This section provides a summary of the risk assessment results, detailing the overall risk exposure and prioritized risks for NX Technologies.

3.1 Asset-Based Risk Assessment

Risk ID	Asset name	Risk title	Threat	Vulnerability	Risk scenario and consequence
R-01	Web Server(Hosted Externally)	Unauthorized access to customer data on the website	External attacker using stolen or phished credentials	MFA is not enforced for administrator access to the hosting console, server and application, and user access is not reviewed periodically.	An attacker gets an admin password through a phishing email. They log in to the website's admin area and copy customer names, emails and course orders. The company must report the breach under GDPR, may get fined, and customers may stop trusting it.
R-02	Cloud-based CRM	Customer data stolen from the CRM	An attacker using a stolen password or an infected laptop	MFA is not turned on for CRM logins, and staff save passwords in browsers on their laptops.	An attacker steals a staff password from an infected laptop and logs in to the CRM. They download the customer list and sales records. The company must report the breach under GDPR, may be fined, and customers may stop trusting it.
R-03	Employee Laptops	Lost or stolen laptop exposes data	Theft or loss while travelling or working remotely	Disk encryption is not enforced on every laptop	Customer data and saved credentials exposed. Likely a reportable incident.
R-04	Google Workspace	Phishing leads to email account takeover	Phishing Emails	MFA is optional for some users; little awareness training	Attacker takes over a mailbox, reads customer data and launches fraud against our customers.
R-05	Third-party Applications	Third-party Application outage	Supplier outage or account suspension	There is no SLA (agreed uptime) with the supplier, no copy of the training materials, and no backup option.	The supplier has an outage or suspends our account over a billing problem. Staff cannot reach training materials for several days. New starters cannot finish onboarding and compulsory training deadlines are missed.
R-06	Cloud Infrastructure	Unauthorized access to	External attacker	Cloud storage access	An attacker discovers publicly accessible

	and Storage	sensitive information stored in cloud storage	exploiting misconfigured cloud storage permissions	permissions are not properly restricted, and access reviews are not conducted regularly.	cloud storage or exploits excessive access permissions. They access and download confidential company documents, employee records and customer information. This may result in a data breach, regulatory consequences, financial losses and reputational damage.

4. Appendix A: Detailed Risk Assessment

Asset-Based Risk Assessment (Detailed)

1. Asset: Web Server Hosted Externally

Asset	Web Server(Hosted Externally)
Risk	Unauthorized access to customer data on the website
Threat	External attacker using stolen or phished credentials
Vulnerability	MFA is not enforced for administrator access to the hosting console, server and application, and user access is not reviewed periodically
Risk Score	20 (High)
Treatment Action	Reduce

2. Asset: Cloud-based CRM

Asset	Cloud-based CRM
Risk	Customer data stolen from the CRM
Threat	An attacker using a stolen password or an infected laptop
Vulnerability	MFA is not turned on for CRM logins, and staff save passwords in browsers on their laptops
Risk Score	20 (High)
Treatment Action	Reduce

3. Asset: Employee Laptops

Asset	Employee Laptops
Risk	Lost or stolen laptop exposes data.
Threat	Theft or loss while travelling or working remotely
Vulnerability	Disk encryption is not enforced on every laptop
Risk Score	12(Medium)
Treatment Action	Reduce

4. Asset: Google workspace

Asset	Google workspace
Risk	Phishing leads to email account takeover

Threat	Phishing email
Vulnerability	MFA is optional for some users; little awareness training
Risk Score	9 (Medium)
Treatment Action	Reduce

5. Asset: Third-party Application

Asset	Third-party Application
Risk	Third-party Application outage
Threat	Supplier outage or account suspension
Vulnerability	There is no SLA (agreed uptime) with the supplier, no copy of the training materials, and no backup option.
Risk Score	9 (Medium)
Treatment Action	Reduce / Transfer

6. Asset: Cloud Infrastructure and Storage

Asset	Cloud Infrastructure and Storage
Risk	Unauthorized access to sensitive information stored in cloud storage
Threat	External attacker exploiting misconfigured cloud storage permissions
Vulnerability	Cloud storage access permissions are not properly restricted, and access reviews are not conducted regularly.
Risk Score	20 (High)
Treatment Action	Reduce